service, that is known as *discretionary access control*, because it's up to the user how much of their access to grant to the third party. OAuth scopes are fundamentally about discretionary access control, while traditional permissions (which you implemented using ACLs in chapter 3) can be used for mandatory access control.

> **DEFINITION** With ***Mandatory Access Control*** (MAC), user permissions are set and enforced by a central authority and cannot be granted by users themselves. With ***Discretionary Access Control*** (DAC), users can delegate some of their permissions to other users. OAuth2 allows discretionary access control, also known as ***delegated authorization***.

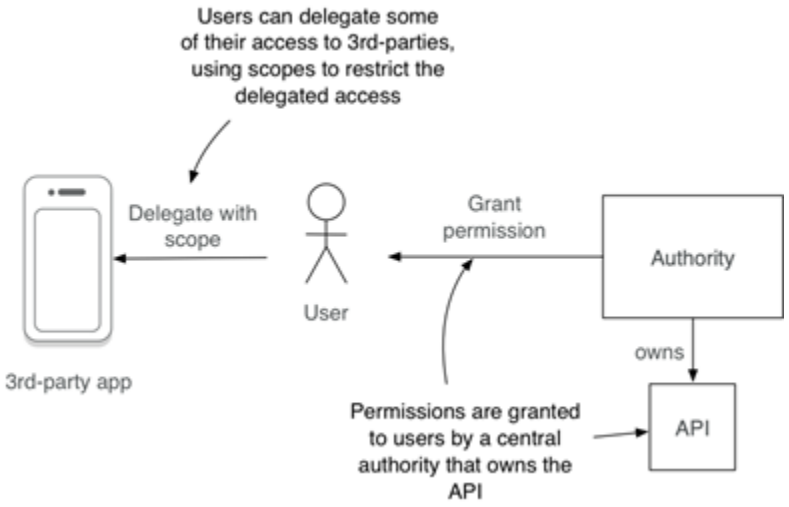



**Figure 7.2 Permissions are typically granted by a central authority that owns the API being accessed. A user does not get to choose or change their own permissions. Scopes allow a user to delegate part of**